

# ABSTRACT

As the banking sector undergoes rapid digital transformation, the number of internal software systems continues to grow, making access control management for development teams increasingly complex. Widely adopted IAM platforms such as Keycloak and Microsoft Azure AD provide comprehensive authentication mechanisms compliant with open standards, yet they do not fully address the operational characteristics of banking environments: permission lifecycles are not tightly coupled with personnel lifecycles, internal approval workflows must be supplemented externally, and immediate permission revocation in response to security incidents still depends on the natural expiry of access tokens. These shortcomings increase security risks and operational overhead.

This thesis takes the approach of building an in-house IAM platform grounded in Role-Based Access Control (RBAC), combined with the OAuth 2.0 and OpenID Connect authentication standards, and deployed on a microservices architecture with event-driven communication. This approach enables deep customization to meet banking-specific requirements while adhering to open protocol standards, and avoids the vendor lock-in risks inherent in commercial solutions.

Based on the selected technologies and methodology, the system was designed and implemented as a complete IAM platform comprising components for authentication, user lifecycle management, authorization configuration, and centralized access enforcement at the API gateway. The correctness of the solution is validated through an internal business application that simulates a software change-and-go-live management process, in which all access control decisions are enforced centrally by the IAM platform.

The thesis makes three principal technical contributions. First, the RBAC model is extended with a second dimension — job position — forming a Role  $\times$  Position permission matrix that automatically provisions default permissions whenever an employee is onboarded or transferred, eliminating manual intervention by administrators. Second, the full permission lifecycle is automated through Kafka events, complemented by a Change Advisory Board (CAB) approval workflow that maintains a complete audit trail for all supplementary permission grants. Third, an instant revocation mechanism propagated via Kafka ensures that active sessions are invalidated within seconds of a permission being revoked, rather than waiting for token expiry as in conventional stateless systems. The outcome is a fully functional IAM platform that directly addresses the limitations of existing commercial solu-

tions in the context of banking software development.